Course Code: ITA1439 Course Name: Ethical Hacking Slot: A

CO2 – ASSIGNMENT_2

Nature of Assignment: Individual Duration: 1 Week Total Marks: 50

Student Name: CH. Ajith Kumar **Reg. No: 192324257**

CO2: Execute footprinting and social-engineering techniques such as DNS analysis, competitive intelligence gathering and attack simulations to collect information for identifying potential security risks.

Assignment Title: Evaluation and Engineering of Footprinting, Reconnaissance and Social Engineering-Awareness Workflows in an Authorized Assessment

Scenario - Assessment Design Philosophy

The assignment is designed for high-performing cybersecurity students and emphasizes the evaluation of reconnaissance and information-gathering choices rather than the mechanical use of tools. Students are expected to formulate an information-gathering strategy, construct difficult test conditions, run footprinting against authorized targets, collect evidence, identify limitations, compare alternatives and defend engineering decisions. All work is performed only against authorized or lab-owned targets, and no attack is launched against live systems or real individuals.

The assessment follows: Understand → Predict → Design → Collect → Analyse → Evaluate → Defend → Validate.

Q1 – Evaluate and Engineer a Footprinting Strategy 8 Marks Problem Context –

Multi-Source Open-Source Information Gathering

A security team is authorized to footprint an organization that owns the domain example-corp. example before a penetration test. Each engagement must gather information from WHOIS, DNS, search engines and public documents, organize it, and use it to understand the target's attack surface.

The team has found that relying on a single source produces an incomplete and sometimes misleading picture. A domain with a clean WHOIS record may still leak information through

DNS, and a quiet DNS footprint may still be exposed through public documents. The strategy must therefore combine several sources and judge their reliability rather than trusting one.

Assessment Challenge

Design a footprinting strategy that combines passive and active techniques (WHOIS, DNS records, search-engine operators and archived pages) and classify each technique as passive or active.

Collect information from an authorized domain using appropriate tools such as whois, nslookup and dig, and organize the findings by source.

Ensure that out-of-scope domains, personal data and unverified results are not treated the same as authorized, verified, in-scope findings.

Construct four contrasting targets: a well-protected domain; a domain that leaks information; a domain with misconfigured DNS; and a domain with a minimal public footprint.

For every target, predict what information will be found before collection and compare it with the actual result.

Record the sources queried and the records found, and identify cases where one source contradicts another.

Evaluate whether the chosen sources are reliable and whether any source produces misleading or outdated information.

Changed Condition: The scope grows from one domain to fifty subdomains and several third party services. Evaluate the original strategy, modify it where necessary, and defend whether it remains suitable for large-scale authorized reconnaissance.

Evidence Expected: Footprinting strategy design, authorized test targets, collected-source records, prediction-versus-observation analysis, source-reliability analysis, scope analysis and a justified final strategy.

Q2 – Build a Reliable DNS Footprinting Workflow 7 Marks Problem Context –

Conflicting and Misconfigured DNS Data

An authorized assessment must map a target's DNS by retrieving A, MX, NS and TXT records and, only where explicitly permitted, attempting a zone transfer. Records may be

inconsistent,

delegated to third parties, cached or misconfigured, so the workflow must interpret the results carefully rather than reporting them at face value.

Assessment Challenge

Develop a DNS footprinting workflow using dig and nslookup that retrieves A, MX, NS and TXT records, and attempts a zone transfer only where authorized.

Evaluate how split-horizon DNS, delegation and caching change the information visible to an external tester.

Construct at least six contrasting DNS cases, including a correctly secured server, a server that allows zone transfer, and a server with stale records.

For each case, predict the records exposed, run the workflow, trace what each query returns, and compare the result with the prediction.

Evaluate whether a misconfigured zone transfer meaningfully changes the attacker's knowledge and the resulting risk.

Introduce a countermeasure such as restricting transfers or using TSIG, and redesign the analysis to show the reduced exposure.

Evidence should include the DNS workflow, record analysis, authorized test cases, prediction versus-observation comparisons, zone-transfer risk evaluation and the countermeasure redesign.

Evidence Expected: DNS workflow, record analysis, authorized test cases, prediction-versus observation, zone-transfer risk evaluation and countermeasure redesign.

Q3 – Create a Competitive-Intelligence Awareness Utility 7 Marks Problem Context –

Public Information and Human-Risk Exposure

A department is building a repeatable workflow that collects public business information about an authorized organization from job advertisements, annual reports, press releases and public profiles, and assesses how that information could support social-engineering attacks such as phishing, vishing, pretexting and tailgating, so that awareness and countermeasures can be designed. No social-engineering attack is performed against real people.

Your Challenge

Design documented steps for each public source and record where each item came from, using search-engine operators such as site, filetype: and intitle.

Map each collected item to the social-engineering technique it could enable (phishing, vishing, pretexting or tailgating) and the indicator a target should notice.

Create test organizations containing rich, sparse and misleading public information. Predict the information and the human-risk level expected from each source before collection.

Evaluate whether the collected information meaningfully increases social-engineering risk and which source is the most dangerous.

Add two new sources or two new awareness countermeasures without restructuring the whole workflow, and evaluate the effect.

Record the sources queried, the items found and the countermeasures recommended.

Inquiry

Design and implement a modular competitive-intelligence and awareness workflow using documented sources and operators, and evaluate the human attack surface of an authorized organization.

Evidence should include the workflow architecture, source operators, item-to-technique mapping, test organizations, prediction-versus-observation and recommended countermeasures.

Evidence Expected: Workflow architecture, source operators, item-to-technique mapping, test organizations, prediction-versus-observation, risk evaluation and recommended countermeasures.

Q4 – Design a Reconnaissance Data-Validation Mechanism 6 Marks Problem Context

– High-Stakes Reconnaissance Data Quality

A reconnaissance data-collection process receives results that may be incomplete, outdated, duplicated or out of scope. Acting on poor-quality data wastes effort and can breach the agreed scope, so each item must be validated before it is used.

Your Challenge

Develop a validation mechanism that checks each collected item for scope, freshness, duplication and source reliability.

Distinguish a recoverable item (one that needs a re-query or confirmation) from an item that must be rejected (out of scope or unverifiable).

Construct at least five test sequences, including all-valid, out-of-scope, stale and duplicated data.

Predict how many items pass, fail or need re-checking before running the validation.

Evaluate whether the order of the validation checks affects effort and accuracy.

Redesign the validation order to reduce unnecessary checks while still keeping out-of-scope data out.

Scalability Inquiry

Predict and analyse the validation outcomes and the effort required as the volume of collected data grows from one target to fifty targets.

Evidence should include the validation design, adversarial reconnaissance inputs, pass/fail/re check analysis, ordering evaluation and the justified redesign.

Evidence Expected: Validation design, adversarial reconnaissance sequences, pass/fail/re check analysis, ordering evaluation and a justified redesign.

Q5 – Evaluate Footprinting of a Hierarchical Organization 7 Marks Problem Context

– Irregular Multi-Level Organizational Footprint

A target organization has a nested public footprint of a parent domain, subdomains, departments and third-party services. Footprinting must traverse this hierarchy level by level, recording each level and stopping cleanly at out-of-scope or terminal nodes.

Your Challenge

Represent the organization's public footprint as a hierarchy (domain, subdomains and services) that can be traversed systematically.

Develop a systematic traversal that records each level and stops at out-of-scope or terminal nodes using an explicit boundary condition.

Construct shallow, deeply nested and irregular footprints with branches of differing size.

Predict the number of nodes and the information expected before the traversal. Evaluate how depth and branching affect the effort and completeness of the footprinting.

Include an empty branch or a node with no public data and evaluate whether the boundary condition handles it correctly.

Compare the systematic traversal conceptually with an ad-hoc, unstructured approach.

Test Your Design

Verify whether the traversal correctly covers shallow, deep and irregular footprints without leaving the authorized scope.

Correctness Inquiry

Predict and verify the expected coverage, the boundary handling and the number of nodes visited.

Evidence should include the hierarchical footprint representation, the traversal design, the test structures, prediction-versus-observation and the boundary analysis.

Evidence Expected: Hierarchical footprint representation, traversal design, test structures, prediction-versus-observation, boundary analysis and a justified final design.

Q6 – Evaluate Footprinting Approaches Under Constraints 7 Marks Problem

Context – Reconnaissance Under Time and Stealth Constraints

An authorized assessment must gather enough information while balancing speed, completeness and the risk of detection. Passive open-source collection and more active footprinting have different trade-offs, so the better approach depends on the scope and the constraints.

Your Challenge

Select two information-gathering approaches, for example passive open-source collection versus active DNS and service footprinting, and define what each produce.

Apply both approaches to the same authorized target.

Test at least four increasing scope sizes, including one at which one approach becomes impractical.

Record the number of queries or steps and the time taken where useful. Evaluate redundant or repeated collection in each approach and identify where effort is wasted. Determine whether the faster or the quieter approach is always the better engineering choice. Defend a recommendation for a small-scope engagement and for a large-scope engagement. **Inquiry**

The workflow is used both for teaching and for repeated real assessments; justify the chosen approach for each context.

Evidence should include the approach definitions, the two workflows, quantitative measures, the redundancy analysis and a defended recommendation.

Evidence Expected: Approach definitions, two workflows, quantitative measures, redundancy analysis and a defended recommendation.

DAY-4 DESIGN CHALLENGE

Q7 – Integrated Review: Diagnose, Redesign and Defend 8 Marks

Select one workflow from Q1–Q6 that demonstrates a meaningful limitation, such as incomplete coverage, an unreliable source, excessive queries, weak validation or a risk of leaving scope, and improve it using evidence.

A. Diagnose the Limitation 2 Marks Identify the reconnaissance or logical bottleneck using evidence.

Determine whether the limitation is caused by source unreliability, redundant collection, poor ordering or a risk of going out of scope.

EVIDENCE EXPECTED

Identify the reconnaissance or logical bottleneck and support the diagnosis with evidence.

Pinpoint the underlying cause of the limitation, such as redundant collection, an unreliable source or poor ordering.

B. Establish Evaluation Criteria 1 Mark Define measurable criteria against which the original workflow will be judged.

Examples include coverage, the number of queries, source reliability, scope compliance and time.

Evidence Expected

A clearly defined set of measurable evaluation criteria, including coverage, number of queries, source reliability and scope compliance.

C. Propose and Implement a Redesign 2 Marks Modify the original workflow to address the diagnosed limitation.

Provide the design logic or the ordered steps before implementation.

Identify any trade-off introduced by the redesign.

Evidence Expected

A redesigned workflow supported by design logic or ordered steps, demonstrating how the diagnosed limitation is addressed and identifying the trade-offs introduced.

D. Validate and Compare 2 Marks Use equivalent test conditions for the original and the redesigned workflow.

Collect quantitative evidence and determine whether the redesign actually improves the selected criterion.

Evidence Expected

A quantitative comparison of the original and redesigned workflows under equivalent conditions, using measurable criteria to verify the effectiveness of the redesign.

E. Defend the Final Engineering Judgment 1 Mark Evaluate whether the redesign met its objective.

Explain cases in which the original workflow may still be preferable.

Defend the final choice using experimental evidence rather than subjective statements.

Evidence Expected

A justified final engineering decision supported by experimental results, evaluating the redesign's effectiveness and identifying cases in which the original workflow remains preferable.

MARK DISTRIBUTION

Question	Assessed Area	Marks
Q1	Footprinting strategy design and evaluation	8
Q2	DNS footprinting and analysis workflow	7
Q3	Competitive-intelligence and awareness utility	7
Q4	Reconnaissance data validation and recovery	6
Q5	Hierarchical organization footprinting	7
Q6	Footprinting approach comparison	7
Q7	Integrated diagnose–redesign–validate challenge	8
TOTAL		**50**

Submission Requirements

Submit:

Assignment report containing evidence for Q1–Q7.

Scripts or documented command sequences for all implemented workflows.

Student-designed authorized test targets and adversarial cases.

Raw collected data and tool outputs.

Prediction-versus-observation comparisons.

Tables/graphs wherever they strengthen the evaluation.

Source, query, item and scope counts where applicable.

Design representation or pseudocode for redesigned workflows.

Execution time may be reported as supporting evidence, but conclusions should not rely solely on timing; coverage, source reliability and scope compliance should form the primary evidence.

Assessment Verification / Viva

Students may be asked to explain and defend their source selection, footprinting methodology, DNS and open-source analysis, scope and authorization decisions, social-engineering awareness reasoning, adversarial test design, measured results, redesign choices and final engineering judgments.

Overall Assessment Expectation

The assignment assesses the student's ability to evaluate information-gathering solutions under realistic, authorized conditions: Problem Interpretation → Prediction → Design → Collection → Adversarial Testing → Measurement → Analysis → Evaluation → Defence → Engineering Judgment.

CO2 – ASSIGNMENT 2

ANSWER REPORT

Scope and evidence note: All target names, DNS records, public-source findings, counts and timing figures in this answer are illustrative lab data created for this assignment. They are not claims about a real organization and no live target or real individual was scanned, queried or contacted. Actual execution must use a written authorization and the exact in-scope asset list. The reserved example namespace is used for documentation; replace it with lab-owned names and attach genuine outputs before submission.

Q1 – EVALUATE AND ENGINEER A FOOTPRINTING STRATEGY (8 MARKS)

1.1 Objective and authorization boundary

The objective is to build a reliable picture of an organization's publicly visible technical footprint by correlating WHOIS/RDAP, DNS, search-engine results and archived public pages. The engagement begins with a signed scope sheet containing the approved registrable domain, permitted subdomains, time window, allowed query types, rate limits, excluded subsidiaries and third-party services. Only assets whose ownership or explicit authorization is confirmed are marked IN_SCOPE. A discovered link is a lead, not automatic permission to test the linked host.

1.2 Passive and active collection strategy

Technique	Classification	Purpose and safe use	Reliability check
WHOIS/RDAP lookup	Passive	Collect registrar, registration dates, nameservers and public organization-level registration data.	Check lookup date, registry/registrar source and privacy-redaction status.
Search operators (site:, filetype:, intitle:)	Passive	Find indexed public subdomains, PDFs, policy pages, job advertisements and technology references.	Record exact query, result URL, publication/update date and whether the page is still accessible.
Web archives	Passive	Review historical public pages and previously exposed technology/contact information.	Record archive snapshot date; never assume an archived hostname is currently active.
dig / nslookup against approved DNS names	Active query	Request A, MX, NS and TXT records from a defined resolver for approved names.	Record resolver, timestamp, TTL, response code and authoritative status.
Direct HTTP/TLS metadata checks	Active, only if in scope	Confirm a publicly exposed service and certificate metadata at a low rate; no login, exploit or intrusive scan.	Compare with DNS and certificate transparency/public records; retain minimal evidence.

Passive collection normally does not send probes to the target's infrastructure; active DNS and service checks generate direct requests and must follow the written rules of engagement. A

search-engine query is passive with respect to the target even though it contacts the search provider.

1.3 Collection procedure and command examples

1. Confirm that example-corp.example (a documentation placeholder) is listed in the signed scope. Record the approving owner, date, permitted subdomains and third-party exclusions.

2. Collect registrar information using: whois example-corp.example. Save the raw output, query time and source. If WHOIS is unavailable or redacted, use the relevant registry RDAP service and mark hidden fields as unavailable, not as absent.

3. Collect DNS records for each approved name: dig example-corp.example A; dig example-corp.example MX; dig example-corp.example NS; dig example-corp.example TXT. Record TTL, resolver, answer and status.

4. Search public indexes using examples such as site:example-corp.example filetype:pdf, site:example-corp.example intitle:careers and site:example-corp.example (inurl:portal OR inurl:login). Search results are leads that must be verified against the agreed scope.

5. Review archived snapshots of the approved public domain and record snapshot timestamps. Treat removed or old hostnames as historical evidence until reconfirmed.

6. Normalize records into a register with fields: item ID, hostname/URL, source, collection time, observation, scope status, confidence, freshness and next action.

7. Correlate sources. For example, an old archived page may mention mail.example-corp.example while the current NS/MX data points to a third-party mail provider. Preserve both observations with dates instead of silently choosing one.

1.4 Four contrasting synthetic targets: prediction versus observation

Synthetic target	Prediction before collection	Simulated observation	Conclusion
A – Hardened: shielded.lab.example	WHOIS privacy; few public DNS records; no indexed files; no useful archived leaks.	RDAP shows privacy proxy; A/NS/MX/TXT are minimal; search returns only a public landing page; archive contains no sensitive material.	Low public exposure. This does not prove absence of internal assets.
B – Information leak: exposed.lab.example	Public docs may reveal staff roles, software names, email formats and old portal URLs.	Two public PDFs and one job post disclose department names, vendor product and support email pattern; an archived page names a retired portal.	Medium exposure. Validate dates and avoid collecting unnecessary personal data.
C – Misconfigured DNS: dns-lab.example	Unexpected TXT entries, stale A record or lab-authorized zone-transfer exposure may reveal hostnames.	Synthetic lab record set contains old A record and, in the deliberately vulnerable lab case only, an AXFR returns test hostnames.	High information exposure in the lab. A transfer result is not permission to access the listed hosts.

Synthetic target	Prediction before collection	Simulated observation	Conclusion
D – Minimal footprint: quiet.lab.example	Little indexed content and limited DNS records; WHOIS may be privacy protected.	Only a basic A and NS answer appear in the simulated dataset; no public docs found; no archived page.	Low observed footprint, but limited public evidence is not evidence of security.

The four observations are simulated test results. In a live authorized engagement, the student must replace them with dated output files and compare each result to the prediction. No real collection is claimed here.

1.5 Source contradictions and reliability

• WHOIS/RDAP may hide registrant data or show the registrar rather than the operational service owner. Treat it as registration evidence, not a complete asset inventory.

• DNS data is time-sensitive. A cached resolver may show an old value; compare authoritative answers, TTL and a second approved resolver before concluding that records conflict.

• Search-engine indexes and archives can retain deleted or stale pages. Use the publication date and a direct current page check where allowed.

• Certificate transparency and public documents can reveal hostnames, but a hostname may be retired, delegated or owned by a provider. Scope confirmation is mandatory.

• Confidence labels: High = current authoritative record plus independent confirmation; Medium = one current reputable source; Low = stale, indexed-only or conflicting evidence. Low-confidence items are leads, not findings.

1.6 Changed condition: fifty subdomains and third-party services

The original one-domain process is not sufficiently controlled at fifty subdomains if it is managed manually. Keep the same source types but introduce an approved asset manifest, automated passive discovery, deduplication, a queue and a review gate. Each discovered hostname is checked against an explicit allowlist or written scope expansion before active queries. Third-party services are tagged THIRD_PARTY and excluded from direct testing unless the provider and engagement owner have authorized it.

At scale, process in batches (for example, ten approved names per batch), cache unchanged responses according to TTL, retain timestamps, and stop on rate-limit or scope warnings. Use a change log and a human review for ambiguous ownership. This preserves coverage while reducing repeated requests and accidental scope expansion. Final strategy: passive-first discovery, scope validation, limited active confirmation and evidence correlation.

Q2 – BUILD A RELIABLE DNS FOOTPRINTING WORKFLOW (7 MARKS)

2.1 Repeatable DNS workflow

1. Load only approved FQDNs from the authorization manifest; normalize case and trailing dots; reject names outside the approved suffix or explicit allowlist.

2. Record the query timestamp, resolver address, network vantage point and target name so that split-horizon differences can be explained.

3. Run dig name A, dig name MX, dig name NS and dig name TXT. Use nslookup -type=A name, nslookup -type=MX name, nslookup -type=NS name and nslookup -type=TXT name as a second-client cross-check.

4. Record ANSWER, AUTHORITY and ADDITIONAL sections, TTL and response status (NOERROR, NXDOMAIN, SERVFAIL or REFUSED). A missing answer is not automatically proof that a record does not exist.

5. Compare recursive-resolver answers with authoritative answers where permitted. Note delegation and CNAME chains rather than flattening them into a single assumed owner.

6. Attempt AXFR only when the rules of engagement explicitly permit a test against the named authoritative lab server: dig @ns1.lab.example lab.example AXFR. Do not try alternate nameservers or domains outside the approved test.

7. Store raw output, normalized records, interpretation and confidence separately. Repeat only when TTL expiry, resolver difference or an observed failure justifies a re-query.

Example command set for an approved lab name: dig lab.example A; dig lab.example MX; dig lab.example NS; dig lab.example TXT; nslookup -type=MX lab.example. Authorized transfer test only: dig @ns1.lab.example lab.example AXFR. The AXFR line is a controlled lab test, not a general instruction to enumerate third-party zones.

2.2 How DNS behaviour changes visibility

• Split-horizon DNS: internal and external clients may receive different answers. The external tester sees only the public view; an internal-only hostname should not be inferred from a missing external answer.

• Delegation: the parent zone's NS records identify child-zone authorities. A third-party nameserver may host records; discovery of that provider does not authorize testing its infrastructure.

• Caching: recursive resolvers may return cached values until TTL expiry. Different resolvers can temporarily disagree. Record TTL, query time and resolver; compare with authoritative data where allowed.

• Negative caching: NXDOMAIN may also be cached. A later record creation may not be visible immediately to all resolvers.

2.3 Six synthetic DNS cases: prediction versus observation

Case	Predicted exposure	Simulated query observation	Interpretation
1. Secure authoritative server	A/MX/NS/TXT public records; AXFR refused.	A and MX answer; NS identifies two lab nameservers; TXT contains SPF policy; AXFR returns REFUSED.	Expected secure configuration; publish only required records.
2. Lab server allows AXFR	Transfer exposes all zone records and hostnames.	Authorized lab AXFR returns six synthetic names, including dev and test records.	Misconfiguration increases mapping knowledge; do not access discovered systems.

Case	Predicted exposure	Simulated query observation	Interpretation
3. Stale A record	Old IP may remain visible until TTL/cache expires.	Resolver returns old synthetic IP with TTL 3600; authoritative answer has updated IP.	Resolver cache is stale; compare vantage points and TTL before reporting.
4. Split-horizon zone	External view should expose fewer records than internal view.	External resolver returns public A/MX; lab internal resolver returns an additional private address.	External tester cannot see internal-only record; avoid treating it as public exposure.
5. Third-party delegation	NS indicates external DNS provider and delegated child zone.	Parent NS points to provider nameservers; child A/MX are served by provider.	Record ownership boundary; only query approved records and respect provider scope.
6. TXT record sprawl	TXT may expose verification tokens, SPF, DKIM or stale service labels.	Simulated TXT contains SPF and a retired verification string; no secret value is assumed.	Remove obsolete tokens and avoid publishing secrets in TXT.

The cases above are a designed test matrix with simulated observations, not measured outputs from a live DNS server. For submission, build the six cases in a local DNS lab or use instructor-provided records and attach the output.

2.4 Zone-transfer risk and countermeasure redesign

A successful AXFR can disclose the zone's complete DNS record set, including forgotten hostnames, development systems, mail routes and service naming patterns. This materially improves an assessor's asset map, but does not itself provide credentials or access. Risk is higher when transferred records are current and identify sensitive exposed services; stale or non-routable records reduce practical risk but still reveal internal naming conventions.

Countermeasures: restrict TCP/53 zone transfers to explicitly approved secondary nameserver IPs; deny AXFR to all other clients; use TSIG authentication between primary and secondary servers; monitor transfer requests; remove retired records; and periodically test configuration. After the change, the authorized external test should return REFUSED or NOTAUTH while a configured secondary with valid TSIG remains able to transfer the zone. Record the before/after difference and test from the permitted lab client only.

Q3 – CREATE A COMPETITIVE-INTELLIGENCE AWARENESS UTILITY (7 MARKS)

3.1 Modular workflow architecture

The utility is an awareness and risk-review tool, not an attack tool. Its modules are: (1) Scope Register, (2) Public Source Collector, (3) Evidence Normalizer, (4) Item-to-Technique Mapper, (5) Human-Risk Scorer, (6) Countermeasure Library and (7) Review/Export. It stores source URLs, dates and business-level information. It avoids profiling private individuals, compiling personal contact dossiers or contacting employees.

Flow: Approved organization → source-specific searches → dated public business evidence → deduplication and provenance → technique/indicator mapping → risk assessment → awareness recommendations → reviewed report.

3.2 Documented sources and search operators

Public source	Example operator / method	Business information to record	Caution
Job advertisements	site:careers.example filetype:pdf; site:example intitle:careers	Roles, technology stack categories, locations and process dependencies.	Do not extract applicants' personal data or infer access permissions.
Annual reports	site:example filetype:pdf intitle:"Annual Report"	Business units, vendors disclosed, operating regions and high-level processes.	Check reporting year and whether a vendor relationship is current.
Press releases	site:example intitle:news OR intitle:press	New services, acquisitions, office openings and public contact channels.	Announcements may be forward-looking or no longer current.
Public organization profiles	Official company profile and verified public organization pages	Department names, published leadership roles and official communication channels.	Do not scrape private profiles or build personal dossiers.

3.3 Mapping public items to social-engineering risk and indicators

Illustrative public item	Potential technique	Warning indicator for staff	Countermeasure
Job post names an ERP platform and finance workflow	Phishing / pretexting	Unexpected invoice or password-reset message using familiar product names.	Verify requests in the approved portal; do not open unexpected attachments.
Annual report identifies a public helpdesk channel	Vishing	Caller pressures staff to reveal codes or bypass identity checks.	Call back using the official directory; never disclose MFA codes.
Press release announces a new office	Pretexting / tailgating	Visitor claims to be a contractor for the new office but lacks a valid visitor record.	Badge, escort and visitor-log policy; verify sponsor.
Official profile lists department functions	Pretexting	Message impersonates an internal department and requests urgent data.	Verify through a second approved channel and use least-privilege access.

3.4 Three synthetic test organizations and prediction versus observation

Test organization	Prediction	Simulated collection observation	Expected human-risk
RichCo – rich public data	Many job posts, annual report, press releases and public business profiles.	Found 8 business-level items: 3 technology/process references, 2 regional references and 3 role/process references.	Medium–High: realistic pretexts possible; awareness training and verification controls reduce impact.
SparseCo – sparse footprint	Few sources and little detail.	Found 2 general public items and no useful process/vendor detail.	Low–Medium: less tailored pretext material; baseline controls still required.
MisleadCo – outdated/misleading material	Old press release and expired job post may imply an obsolete vendor or office.	Found 5 items, 3 older than two years and one superseded service reference.	Medium if staff trust old details; confidence penalty and freshness review are essential.

The counts and content above are simulated. Rich public information does not automatically mean that an organization is vulnerable; risk depends on whether the information enables a plausible deception and whether staff controls detect it. The most concerning source is often a recent job advertisement or operational announcement that reveals current processes, but the conclusion must be based on freshness, specificity and the organization's exposure.

3.5 Two additional awareness countermeasures

• Add a published verification directory and callback rule: staff should use official contact details already held in the directory, not the phone number supplied by an unexpected caller. This reduces vishing and pretexting risk.

• Add visitor/contractor verification and anti-tailgating controls: pre-registration, visible badges, escorted access and a simple challenge/report procedure. This reduces physical pretexting risk.

Effect evaluation: in the simulated review, applying both countermeasures reduces the risk rating for vishing and tailgating scenarios by one level because staff have an independent verification method. This is a design assessment, not a measured reduction in real incidents.

Record every item with a source URL, retrieval date, publication date, business relevance, confidence and retention decision. Do not include private personal data, inferred passwords, private contact details or instructions for targeting individuals.

Q4 – DESIGN A RECONNAISSANCE DATA-VALIDATION MECHANISM (6 MARKS)

4.1 Validation rules and outcome categories

Each collected item is represented as {item_id, asset, source, observed_value, collected_at, published_at, scope_status, source_reliability, fingerprint}. Validation returns PASS, RECHECK or REJECT. PASS means in-scope, current enough for the defined purpose, unique and supported by a reliable source. RECHECK means the item may be useful but

needs a new query or independent confirmation. REJECT means out of scope, unverifiable, or an exact duplicate already represented by a canonical record.

• Scope: must match the written domain/asset allowlist. Out-of-scope items are rejected immediately and are not actively queried.

• Duplicate: normalize hostname/URL/value and compare a stable fingerprint. An exact duplicate is linked to the canonical record, not counted again.

• Freshness: use a policy such as DNS observations within 7 days for a fast-changing record and public documents within 365 days unless the task specifically requires historical context. Older items are rechecked or retained only as historical evidence.

• Reliability: authoritative registry/DNS and official organization sources receive higher confidence than snippets, reposts or unattributed pages. Unverifiable items are rejected; conflicting credible sources are rechecked.

4.2 Validation pseudocode

FOR each item in collected_items: normalize(item); IF not in_scope(item): REJECT and continue; IF duplicate(item): link_to_canonical_record; REJECT_DUPLICATE and continue; IF stale(item): schedule_requery; RECHECK and continue; IF source_is_unverifiable(item): REJECT and continue; IF confidence_below_threshold(item): RECHECK and continue; otherwise PASS. Log the reason, rule version and timestamp for every decision.

4.3 Five adversarial test sequences: predicted and simulated outcomes

Sequence	Input records	Prediction	Simulated result
S1 – all valid	5 in-scope, current, unique records from official/authoritative sources.	5 pass; 0 reject; 0 recheck.	5 PASS.
S2 – out of scope	3 in-scope valid + 2 unrelated domains.	3 pass; 2 reject before any re-query.	3 PASS; 2 REJECT.
S3 – stale	2 current records + 3 old DNS/document observations.	2 pass; 3 recheck.	2 PASS; 3 RECHECK.
S4 – duplicated	4 unique valid records plus 3 repeated copies.	4 pass; 3 duplicate rejects/links.	4 PASS; 3 REJECT_DUPLICATE.
S5 – mixed adversarial	2 valid + 1 out-of-scope + 1 stale + 1 duplicate + 1 unverifiable.	2 pass; 2 reject (scope/unverifiable) plus 1 duplicate reject; 1 recheck.	2 PASS; 3 REJECT; 1 RECHECK.

The predictions are made before the simulated validation and the outcomes match them. A duplicate is rejected as a separate record but linked to the canonical entry so that evidence is not lost.

4.4 Why validation order matters and redesigned order

A costly reliability review or re-query performed before checking scope wastes effort on records that cannot be used. A redesigned low-cost-to-high-cost order is: (1) normalize syntax, (2) scope check, (3) deduplicate, (4) freshness/TTL check, (5) source reliability and

independent confirmation. Scope is always checked before an active re-query. The trade-off is that normalization and deduplication must be reliable; overly broad deduplication could merge two legitimately different records.

4.5 Growth from one to fifty targets

For one target with 100 collected items, a manual review is manageable but inconsistent. At fifty targets, the same process can produce approximately 5,000 items if the average remains 100 per target. Use a queue, normalized asset IDs, fingerprints, TTL-based freshness rules and batch reports. Scope validation should be automated and fail closed; low-confidence or ambiguous ownership cases go to a human reviewer. Estimate: at 5,000 items, a four-check manual review would require up to 20,000 checks, while the staged pipeline avoids later checks for rejected items and reduces unnecessary re-queries. The exact benefit depends on the proportion of out-of-scope, duplicate and stale items.

Q5 – EVALUATE FOOTPRINTING OF A HIERARCHICAL ORGANIZATION (7 MARKS)

5.1 Hierarchical representation and boundary

Represent the footprint as a rooted tree. Each node contains {name, type, parent, scope_status, terminal, public_data_status, children}. The root is the authorized parent domain. Children may be subdomains, departments represented by public pages, or explicitly approved service endpoints. A third-party provider is a terminal/excluded node unless written authorization explicitly adds it to scope.

Boundary condition: visit a node only if it is inside the approved asset manifest and within the permitted depth; stop expanding when the node is out of scope, terminal, has no public data, or reaches the configured maximum depth. An empty child list is a normal leaf, not an error.

5.2 Systematic traversal pseudocode

Use breadth-first traversal so that each level is recorded before deeper levels: queue ← [(root, 0)]; visited ← empty set; while queue not empty: remove (node, depth); if node already visited continue; mark visited; if node is out of scope or terminal or depth = MAX_DEPTH, record boundary reason and continue; collect permitted public metadata; if no public data, record EMPTY and continue; for each child in approved manifest, add (child, depth + 1) to queue. Never discover and actively query a child merely because a page links to it; check scope first.

5.3 Test structures, predicted counts and simulated coverage

Structure	Synthetic hierarchy	Predicted nodes	Simulated visit result
Shallow	Root → {www, mail, careers}; all in scope.	4 total nodes.	4 visited; all 4 recorded.
Deep	Root → app → api → v1 → status; plus one empty branch under api.	6 total nodes including empty branch.	6 visited; expansion stops at empty branch; no child is fabricated.
Irregular	Root has 2 subdomains; first has 3 children, second has 1 child; one child is third-party and out of scope.	7 discovered nodes total; 6 in scope, 1 excluded.	7 classified; 6 in-scope recorded, 1 scope boundary; no traversal beyond third party.

Counts are illustrative test-tree counts. Prediction and simulated observation agree by construction. In real use, record the discovered and visited node IDs separately so that a discovery is not mistaken for permission to inspect.

5.4 Depth, branching and empty-branch handling

• Depth increases the number of sequential levels and often increases the need to confirm ownership and relevance at every step.

• Branching increases the number of nodes at a level; a breadth-first queue makes the workload visible and prevents a deep branch from hiding sibling branches.

• An empty branch is marked NO_PUBLIC_DATA and terminates normally. It must not be retried indefinitely.

• Cycles or repeated references are controlled with a visited set; duplicate nodes are linked to the canonical node.

5.5 Systematic versus ad-hoc approach

Systematic traversal provides reproducible coverage, a record of every boundary decision and predictable stopping rules. An ad-hoc approach may be faster for a very small target but can overlook sibling branches, revisit the same host, and follow links outside scope. The tree approach is preferred for auditability; human review remains necessary when ownership is unclear.

Q6 – EVALUATE FOOTPRINTING APPROACHES UNDER CONSTRAINTS (7 MARKS)

6.1 Two approaches and outputs

Approach A – Passive-first OSINT: WHOIS/RDAP, search engines, official public pages, job advertisements, public reports and archives. Output is a dated list of public names, business facts, historical references and source-confidence labels. It creates little or no direct traffic to the target but may be stale or incomplete.

Approach B – Active DNS confirmation: approved dig/nslookup requests for A, MX, NS and TXT records, with low-rate service metadata checks only when explicitly permitted. Output is current DNS evidence and selected service metadata. It can confirm current configuration but creates traffic, may trigger monitoring and must be tightly scoped.

6.2 Same synthetic target and increasing scope sizes

Test target for the comparison: authorized lab organization atlas-lab.example, with the same asset manifest supplied to both workflows. The following table is a simulated planning experiment, not real measurements. Time estimates include analyst review but exclude setup.

Scope	Passive queries / time	Active queries / time	Main observation
1 domain	6 queries / 4 min	4 queries / 3 min	Both are practical; active confirms current records.
5 subdomains	18 / 8 min	20 / 12 min	Active queries begin to repeat common NS/MX data.
20 subdomains	52 / 18 min	80 / 40 min	Passive collection scales better; active effort rises with each record type.

Scope	Passive queries / time	Active queries / time	Main observation
50 subdomains	120 / 35 min	200 / 105 min	Active workflow becomes costly and noisy; prioritize only records with a defined validation need.

6.3 Redundancy and engineering judgement

Passive sources can repeat the same hostname across search indexes, archived pages and copied PDFs. Deduplicate by normalized URL/hostname and preserve provenance from each source. Active collection can repeat identical NS/MX answers for many subdomains; cache zone-level results according to TTL and query only the records required by the assessment. Avoid sending the same request repeatedly unless the previous answer expired or a discrepancy needs resolution.

The faster or quieter method is not always better. A passive source can be outdated and miss current DNS changes; an active query can resolve uncertainty but may generate detectable traffic. The correct choice depends on the objective, written scope, sensitivity, freshness need and risk tolerance.

6.4 Recommendations

• Small-scope engagement: use passive-first collection followed by a small number of low-rate active DNS checks to confirm important leads. This provides a balance of completeness and effort.

• Large-scope engagement: use automated passive discovery, scope validation, deduplication and risk-based active sampling/confirmation. Use per-domain query budgets, TTL-aware caching, rate limits and stop conditions.

• Teaching: use synthetic domains and prebuilt DNS zones so students can compare expected outputs safely and repeatably.

• Real assessment: follow the signed authorization, coordinate with the asset owner, identify third-party exclusions, preserve raw evidence and obtain approval before broad active queries.

Q7 – INTEGRATED REVIEW: DIAGNOSE, REDESIGN AND DEFEND (8 MARKS)

Selected workflow: Q4 reconnaissance data validation

A. Diagnose the limitation (2 marks)

The original validation workflow can waste effort when freshness and source-reliability checks occur before scope validation and deduplication. An out-of-scope record may trigger unnecessary confirmation, while repeated copies of the same result may be checked many times. The bottleneck is poor ordering and redundant collection, with a scope-control risk if the team re-queries a discovered third-party hostname before authorization.

B. Establish measurable evaluation criteria (1 mark)

• Scope compliance: 100% of out-of-scope records are rejected before any active re-query.

• Coverage: retain every unique valid item; target at least 95% of the known valid test set.

• Duplicate handling: 100% of exact duplicates link to a canonical record and are not counted twice.

• Efficiency: reduce total validation checks and unnecessary re-queries by at least 15% without reducing valid-item coverage.

• Freshness and reliability: every passing item has a collection date and a source-confidence decision.

C. Propose and implement the redesign (2 marks)

Original order: reliability review → freshness review → duplicate check → scope check. Redesigned order: normalize → scope gate → duplicate check → freshness check → reliability/confirmation. The scope gate is first because it is both mandatory and inexpensive. Deduplication comes next to avoid repeatedly reviewing identical records. Higher-effort confirmation is reserved for in-scope, unique, stale or uncertain items.

Trade-off: a false-positive duplicate decision could hide a distinct record, so the fingerprint includes record type, normalized asset, value and observation date. Ambiguous matches are sent to manual review rather than automatically discarded.

D. Validate and compare (2 marks)

Equivalent simulated test set: 100 records, of which 50 are unique valid/current/in-scope, 10 are out of scope, 15 are exact duplicates, 20 are stale and need re-query, and 5 are unverifiable. The groups are mutually exclusive for this calculation.

Measure	Original workflow	Redesigned workflow
Pass	50	50
Reject	30 (10 out of scope + 15 duplicates + 5 unverifiable)	30 (same categories)
Recheck	20 stale records	20 stale records
Validation checks (modeled)	4 checks × 100 = 400	100 scope + 90 dedup + 75 freshness + 55 reliability = 320
Check reduction	Baseline	80 fewer checks (20% reduction)
Valid coverage	50/50 known valid = 100%	50/50 known valid = 100%
Out-of-scope re-query	Possible before late scope gate	0; rejected at first gate

The original and redesigned workflows produce the same final classification in this constructed dataset. The redesign reduces modeled checks by 20% and prevents out-of-scope re-queries. The result is evidence from a structured simulation, not measured production performance.

E. Defend the final engineering judgment (1 mark)

The redesign meets its objective in the test case: coverage is unchanged, all out-of-scope items are rejected, duplicate records are controlled and the number of checks is lower. The original order may remain useful when the input set is already guaranteed to be in scope and source verification is the dominant risk, or when deduplication could be unsafe because record identities are ambiguous. For general authorized reconnaissance, scope-first validation is the safer default because it prevents wasted work and reduces the chance of accidental out-of-scope activity.

FINAL CONCLUSION

A dependable footprinting assessment combines multiple public sources, validates DNS carefully, converts public business information into defensive awareness guidance, checks every item for scope and quality, and traverses the organization's footprint using explicit boundaries. The strongest approach is not the one that collects the most data; it is the one that

collects enough relevant information, preserves provenance, controls scope, tests predictions against observations and explains uncertainty. All live activity must remain within written authorization.

TOOLS, COMMANDS AND EVIDENCE ACKNOWLEDGEMENT

Tools referenced: whois/RDAP, dig, nslookup, search-engine operators, public web archives, a structured evidence register and a validation script or spreadsheet. The command examples are for approved lab-owned or explicitly authorized targets. No real target was queried and no real organization/person was assessed in preparing this report. The simulated outputs, test structures and quantitative comparisons must be replaced or supplemented with the student's own raw tool output, screenshots and execution logs where the instructor requires practical evidence.